

Guía metodológica de la Encuesta sobre Agentic IA y Ciberseguridad

1. Objetivo general

La presente guía describe cómo utilizar la encuesta integral para evaluar el grado de madurez, riesgo y alineamiento normativo de las organizaciones respecto a la Agentic IA y los ataques impulsados por agentes autónomos. El propósito no es dictar sentencias, sino iluminar, con cierta ironía constructiva, hasta qué punto los agentes están mejor gobernados que algunos procesos humanos.

2. Fundamento conceptual

La encuesta se apoya en tres pilares:

- El perfil de gestión de riesgos de Agentic IA del Center for Long-Term Cybersecurity de UC Berkeley (CLTC), que extiende el NIST AI RMF a los riesgos específicos de agentes autónomos (delegación, escalado de privilegios, memoria, etc.).
- La guía de la AEPD sobre Agentic IA y protección de datos, que aterriza el RGPD en el contexto de agentes capaces de planear y ejecutar acciones con autonomía.
- El marco multicapa de ENISA para buenas prácticas de ciberseguridad en IA, que articula prácticas base, específicas de IA y sectoriales.

3. Alcance y unidades de análisis

- Unidad primaria: organización (empresa, administración, entidad).
- Unidades secundarias:
 - Conjunto de agentes de IA desplegados (catálogo de agentes).
 - Equipos de gobierno (CISO, DPO, etc.).
 - SOC interno/externo.

La encuesta está pensada para ser respondida por un equipo reducido (idealmente CISO + DPO + responsable de TI y/o riesgos), de forma conjunta.

4. Dimensiones de análisis

Las preguntas cubren nueve dimensiones:

1. Datos generales y contexto.
2. Uso de Agentic IA.
3. Gobernanza y responsabilidades.
4. Datos, memoria y superficie de ataque.
5. Métricas de comportamiento (UAR, PAR, PED, etc.).
6. Métricas operativas de SOC.
7. Cumplimiento normativo.
8. Capacitación, cultura y transparencia.
9. Experiencia con incidentes y visión estratégica.

Cada dimensión permite asignar un Índice de Grado de Madurez (IGM) parcial y un IGM global para la organización.

5. Escalas y codificación de respuestas

5.1. Escala de madurez

Se propone mapear cada respuesta a una escala de 0 a 4:

- 0 = Inexistente / No se realiza / No se considera.
- 1 = Inicial / Ad hoc.
- 2 = Definido / En implementación.
- 3 = Gestionado / Sistemático.
- 4 = Optimizado / Revisado y mejorado regularmente.

Ejemplo:

- “No se realiza” → 0.
- “En diseño / preparación” → 2.
- “Sí, formalizado y aplicado” → 3 o 4, según se evidencie mejora continua.

5.2. Ponderación

Se recomienda asignar pesos por dimensión, por ejemplo:

- Uso de Agentic IA: 10 %.
- Gobernanza y responsabilidades: 20 %.
- Datos, memoria y superficie de ataque: 15 %.
- Métricas de comportamiento: 20 %.
- Métricas de SOC: 15 %.
- Cumplimiento normativo: 10 %.
- Capacitación y cultura: 5 %.
- Incidentes y visión estratégica: 5 %.

El IGM global será la suma ponderada de las puntuaciones normalizadas por dimensión.

6. Procedimiento de aplicación

10. Preparación
11. Identificar a los participantes clave (CISO, DPO, etc.).
12.
Remitir la encuesta y esta guía con antelación.
13.
Sesión de respuesta conjunta
14. Programar una sesión (90–120 minutos).
15.
Responder a la encuesta de manera consensuada, documentando desacuerdos.
16.
Codificación y cálculo del IGM
17. Asignar puntuaciones numéricas según la escala de madurez.
18.
Calcular los índices de cada dimensión y el IGM global.
19.
Análisis de brechas
20. Comparar resultados con expectativas internas o benchmarks sectoriales (si se dispone).
21.
Identificar áreas de alto riesgo: especialmente donde hay uso intensivo de Agentes IA y baja madurez en métricas o gobernanza.
22.
Informe y plan de acción
23. Utilizar la plantilla de reporte ejecutivo para presentar resultados a la dirección.
24. Definir medidas prioritarias: por ejemplo, implantación de UAR/PAR, aplicación de la Regla de 2, etc.

Remitir la encuesta y esta guía con antelación.

Sesión de respuesta conjunta

Responder a la encuesta de manera consensuada, documentando desacuerdos.

Codificación y cálculo del IGM

Calcular los índices de cada dimensión y el IGM global.

Análisis de brechas

Identificar áreas de alto riesgo: especialmente donde hay uso intensivo de Agentes IA y baja madurez en métricas o gobernanza.

Informe y plan de acción

7. Consideraciones normativas

- RGPD y AEPD: La encuesta ayuda a revisar el cumplimiento de principios de minimización, licitud, transparencia, responsabilidades del responsable y del encargado, así como la necesidad de EIPD específicas.
- NIST AI RMF y perfil de Agentes IA: La encuesta dialoga con las funciones de Gobernar, Mapear, Medir y Gestionar, especialmente en el monitoreo de métricas como UAR, PAR y PED.
- ENISA: La relación con el marco multicapa permite evaluar en qué medida se han incorporado prácticas de ciberseguridad específicas de IA y sectoriales.

8. Interpretación de resultados

8.1. Ejemplo de bandas de madurez

- IGM global 0–1,4: Nivel incipiente.
- 1,5–2,4: Nivel intermedio.
- 2,5–3,4: Nivel avanzado.
- 3,5–4: Nivel líder.

8.2. Alertas tempranas

Prestar atención especial a combinaciones peligrosas:

- Uso intensivo de agentes + ausencia de DPIA/EIPD.
- Acceso a datos sensibles + falta de políticas de memoria y minimización.
- Automatización de SOC + ausencia de métricas UAR/PAR y TTC.

9. Limitaciones y futuras iteraciones

Esta herramienta captura un retrato detallado, pero no sustituye auditorías técnicas ni pruebas de penetración específicas contra agentes. Se recomienda actualizar la encuesta al menos una vez al año, incorporando la evolución de marcos como el perfil de Agentes IA, los informes de ENISA y futuras guías regulatorias.

10. Epílogo

Si, al terminar la encuesta, la organización descubre que los agentes saben más de ella que ella misma, la misión ha sido un éxito: se ha hecho visible la necesidad de pasar del entusiasmo tecnológico a la gobernanza madura, sin perder el sentido del humor.